UNIVERSIDAD NACIONAL AUTÓNOMA DE MÉXICO

FACULTAD DE INGENIERÍA

SISTEMAS OPERATIVOS

SEMESTRE 2026 - 2

EL ATAQUE DE LA CADENA DE SUMINISTRO XZ

INTEGRANTES	*Campos Cortes Isaac* *Martínez Pérez Alejandro*
PROFESOR	*Gunnar Eyal Wolf Iszaevch*
GRUPO	*04*
FECHA DE ENTREGA	*16 de abril de 2026*

Ciudad de México 17 de abril de 2026

1. Introducción

La seguridad informática moderna no depende únicamente de proteger computadoras o redes locales, sino también de asegurar la cadena de suministro del software. Esto significa verificar no solo el programa final que se instala, sino también las bibliotecas, herramientas, mantenedores, repositorios, sistemas de compilación y mecanismos de distribución que participan en su construcción.
En 2024 se descubrió uno de los incidentes más preocupantes en el ecosistema de software libre reciente: el caso de XZ Utils, identificado como {CVE-2024-3094. Este incidente evidenció que un proyecto ampliamente usado en sistemas Linux podía ser comprometido de forma sigilosa durante el proceso de publicación y construcción, afectando una biblioteca crítica del sistema.
El caso XZ se volvió especialmente relevante porque el código malicioso no se introdujo de manera obvia en el repositorio principal, sino mediante mecanismos cuidadosamente ocultos dentro de los archivos de distribución y el flujo de construcción. Por ello, este evento es considerado un ejemplo emblemático de ataque a la cadena de suministro.

2. Objetivos

2.1. Objetivo general

Analizar el ataque de la cadena de suministro XZ, sus características técnicas, su impacto potencial y las lecciones que deja para la seguridad del software.

2.2. Objetivos específicos

- Explicar qué es un ataque a la cadena de suministro de software.
- Describir el incidente de XZ Utils y cómo fue detectado.
- Identificar las versiones y sistemas potencialmente afectados.
- Analizar las implicaciones del ataque en la seguridad de Linux y del software de código abierto.
- Presentar medidas para reducir riesgos similares en el futuro.

3. Marco teórico

3.1. Cadena de suministro de software

La cadena de suministro de software incluye todos los elementos involucrados en la creación y distribución de un programa: desarrolladores, repositorios, dependencias, sistemas de integración, empaquetado y canales de actualización. Cuando un atacante compromete cualquiera de esos puntos, puede insertar componentes maliciosos que terminan distribuyéndose como si fueran legítimos.

A diferencia de un ataque directo a un usuario final, un ataque a la cadena de suministro busca comprometer una pieza confiable del ecosistema para alcanzar una gran cantidad de objetivos indirectamente.

3.2. ¿Qué es XZ Utils?

XZ Utils es un conjunto de herramientas de compresión ampliamente utilizado en sistemas tipo Unix y Linux. Incluye la biblioteca liblzma, que puede ser usada por otros programas y servicios del sistema. Debido a su presencia en distribuciones Linux y procesos de empaquetado, cualquier manipulación maliciosa de esta biblioteca representa un riesgo significativo.

4. Desarrollo

4.1. Descripción técnica del exploit

Desde el punto de vista técnico, el caso XZ no consistió en una vulnerabilidad accidental ni en una modificación evidente dentro del código fuente revisado normalmente. El ataque fue introducido en los *tarballs* oficiales de las versiones 5.6.0 y 5.6.1 de XZ Utils, donde se añadieron archivos y macros de construcción adicionales que no estaban presentes de la misma forma en el repositorio Git visible del proyecto. Durante el proceso de compilación, estos elementos activaban una cadena de instrucciones ofuscadas capaz de extraer un objeto precompilado oculto dentro de supuestos archivos de prueba, para después incorporarlo a la construcción de `liblzma`.

El objetivo de esta manipulación era alterar el artefacto final generado por el proceso de *build*, de modo que la biblioteca compilada incluyera comportamiento malicioso sin que éste resultara obvio en una revisión superficial del código fuente. Además, la carga no se activaba en cualquier entorno, sino que incluía diversas condiciones para ejecutarse únicamente en sistemas Linux `x86_64`, compilados con herramientas específicas como `gcc` y `GNU ld`, y en contextos de empaquetado asociados con distribuciones importantes. Esta selectividad hacía al backdoor más difícil de detectar, reproducir y analizar.

Una vez construida e instalada la biblioteca alterada, el exploit aprovechaba mecanismos internos del enlazado dinámico. De acuerdo con los análisis iniciales, el código inyectado intervenía en resolutores *IFUNC* relacionados con funciones de `crc32` y `crc64`, reunía información del entorno de ejecución y colocaba un *audit hook* en el enlazador dinámico. Posteriormente esperaba a que se resolviera el símbolo `RSA_public_decrypt` dentro del contexto de ejecución de `sshd`, redirigiendo dicha resolución hacia código controlado por el atacante.

Es importante precisar que `OpenSSH` no enlaza directamente con `liblzma`. El riesgo aparecía en ciertos entornos donde `sshd` quedaba vinculado indirectamente con esta biblioteca a través de otras dependencias del sistema, como `libsystemd`. Bajo esas condiciones, el código malicioso podía intervenir en una ruta crítica del proceso de autenticación, lo que abría la posibilidad de ejecución remota de código antes de una autenticación completa y legítima del usuario.

Lo más notable del exploit fue su sofisticación en varias etapas. Primero, comprometía la cadena de suministro mediante artefactos de publicación manipulados; después, ocultaba su carga dentro del proceso de construcción; finalmente, se integraba en tiempo de ejecución usando mecanismos normales del enlazado dinámico y funciones criptográficas sensibles.

Esta combinación de compromiso de la cadena de suministro, ofuscación en tiempo de compilación e intercepción en tiempo de ejecución es lo que convierte al caso XZ en uno de los incidentes más avanzados y preocupantes del ecosistema reciente de software libre.

4.2. Cómo fue descubierto

El problema fue descubierto por Andres Freund, quien observó comportamientos extraños en sistemas Debian sid, entre ellos un uso anormal de CPU en conexiones SSH y errores detectados mediante valgrind. A partir de estas anomalías inició una investigación que llevó al hallazgo del backdoor.
Este aspecto es especialmente importante porque el incidente no fue detectado primero por un escáner automático ni por una auditoría rutinaria, sino por la observación cuidadosa de una degradación de rendimiento aparentemente menor.

4.3. Relación con OpenSSH y liblzma

El riesgo principal del caso XZ radicó en que liblzma podía ser utilizada por software crítico del sistema. Distintos análisis señalaron que, en determinados entornos, la biblioteca modificada podía influir en el comportamiento de sshd, permitiendo una posible ejecución controlada por el atacante bajo condiciones específicas.
Esto convirtió un paquete de compresión, que en apariencia parecía poco sensible, en un vector con capacidad de comprometer servicios remotos de alto valor.

4.4. Versiones y sistemas afectados

Las versiones asociadas al incidente fueron XZ Utils 5.6.0 y 5.6.1. La afectación práctica fue más visible en distribuciones de desarrollo o prueba. Red Hat indicó afectación en Fedora Rawhide y en ciertos paquetes beta de Fedora 40, recomendando revertir a la rama 5.4.x. Debian también rastreó el incidente en sus ramas relacionadas con paquetes inestables y de prueba.
Aunque el impacto potencial era extremadamente grave, la respuesta rápida de la comunidad y de distribuidores evitó una propagación masiva a sistemas de producción ampliamente desplegados.

4.5. Por qué este ataque fue tan grave

El impacto potencial del caso XZ iba mucho más allá de comprometer una biblioteca de compresión. Como el código malicioso estaba orientado a interferir con el proceso de autenticación de sshd en ciertos entornos Linux, el escenario más grave era la obtención de acceso remoto no autorizado a servidores expuestos a Internet. Dado que sshd es un servicio central de administración remota y que en muchos sistemas corre con privilegios elevados, una explotación exitosa habría podido traducirse en control total del equipo, movimiento lateral dentro de redes corporativas y compromiso de infraestructura crítica. Además, al tratarse de un componente distribuido mediante paquetes aparentemente legítimos, el alcance habría sido especialmente peligroso: no se trataría de una intrusión aislada en una sola máquina, sino de una propagación a través de la propia confianza depositada en repositorios, mantenedores y procesos de empaquetado. El hecho de que organismos de respuesta y distribuidores

recomendaran priorizar los activos expuestos a Internet muestra que el riesgo operativo más serio estaba precisamente en sistemas accesibles por SSH.

5. Análisis

El ataque de la cadena de suministro XZ demuestra que incluso proyectos abiertos y ampliamente auditables pueden ser vulnerables cuando existe presión sobre mantenedores, complejidad en los procesos de publicación y confianza excesiva en artefactos de compilación.
También deja claro que la transparencia del código fuente por sí sola no basta si los artefactos finales distribuidos no son verificables de manera independiente. Una de las lecciones más importantes del caso es la necesidad de fortalecer prácticas como:

- compilaciones reproducibles;
- revisión independiente de tarballs y artefactos publicados;
- validación entre repositorio y paquete distribuido;
- monitoreo de cambios sospechosos en proyectos críticos;
- mejor apoyo a mantenedores de software esencial.

El caso XZ también resalta el valor de la comunidad técnica y de la divulgación coordinada. Una respuesta rápida entre investigadores, distribuciones Linux y equipos de seguridad permitió contener el problema antes de que se convirtiera en una crisis de mayor alcance.
Otro aspecto importante es que el daño potencial no dependía únicamente del número de sistemas afectados en ese momento, sino de cuán cerca estuvo el backdoor de llegar a entornos de producción más amplios. Las versiones comprometidas ya habían entrado en ramas de prueba o desarrollo de distribuciones relevantes, y Red Hat, Debian y otros equipos reaccionaron con urgencia para revertirlas o aislarlas. Si el problema no hubiera sido detectado antes de su adopción masiva en versiones estables, el incidente habría podido convertirse en una crisis de gran escala para administradores, proveedores de nube, imágenes base de contenedores y sistemas automatizados de despliegue, obligando a auditorías, reconstrucciones y rotación de credenciales a gran escala.

6. Conclusiones

El ataque de la cadena de suministro XZ fue uno de los incidentes de seguridad más relevantes de 2024 dentro del software libre y del ecosistema Linux. Su importancia no solo radica en el backdoor descubierto, sino en la forma en que fue introducido: con sigilo, paciencia y aprovechando puntos débiles de confianza dentro del proceso de publicación.
Este caso demuestra que la seguridad del software debe entenderse de manera integral. No basta con proteger el código visible; también es necesario asegurar bibliotecas, empaquetados, sistemas de construcción y procesos de distribución.
Finalmente, el incidente deja una enseñanza central: los ataques modernos pueden dirigirse a piezas pequeñas, poco visibles pero muy influyentes del ecosistema. Por ello, la verificación, la trazabilidad y la auditoría continua son elementos esenciales para proteger la infraestructura digital.

7. Referencias

1. Red Hat. *CVE-2024-3094*. Disponible en: https://access.redhat.com/security/cve/cve-2024-3094
2. National Vulnerability Database (NVD). *CVE-2024-3094 Detail*. Disponible en: https://nvd.nist.gov/vuln/detail/CVE-2024-3094
3. Andres Freund. *backdoor in upstream xz/liblzma leading to ssh server compromise*. Openwall OSS-Security. Disponible en: https://www.openwall.com/lists/oss-security/2024/03/29/4
4. Red Hat. *Urgent security alert for Fedora 40 and Fedora Rawhide users*. Disponible en: https://www.redhat.com/en/blog/urgent-security-alert-fedora-40-and-rawhide-users
5. Debian. *CVE-2024-3094 - Security Tracker*. Disponible en: https://security-tracker.debian.org/tracker/CVE-2024-3094
6. Debian Security Advisory. *DSA-5649-1 xz-utils security update*. Disponible en: https://www.debian.org/security/dsa-5649-1